

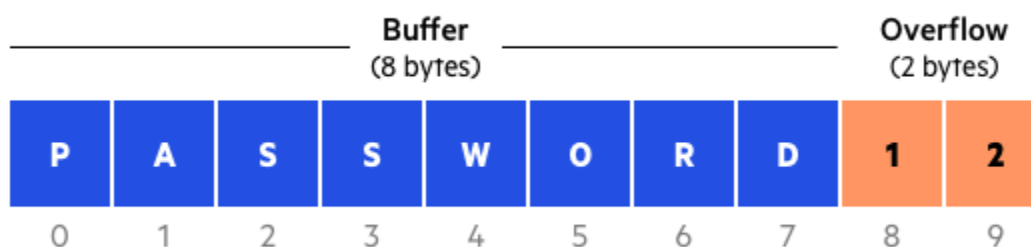
Vulnerability:

- An application security vulnerability is a security bug, flaw, error, fault, hole, or weakness.
- Software architecture, design, code, or implementation that can be exploited by attackers.
- An application security vulnerability is “a hole or a weakness or fault in the application.
- Weaknesses: “Software weaknesses are flaws, faults, bugs, vulnerabilities, and other errors.
- In computer security, a vulnerability is a weakness which can be exploited by an attacker.
- To exploit a vulnerability, an attacker must have at least one applicable tool or technique.



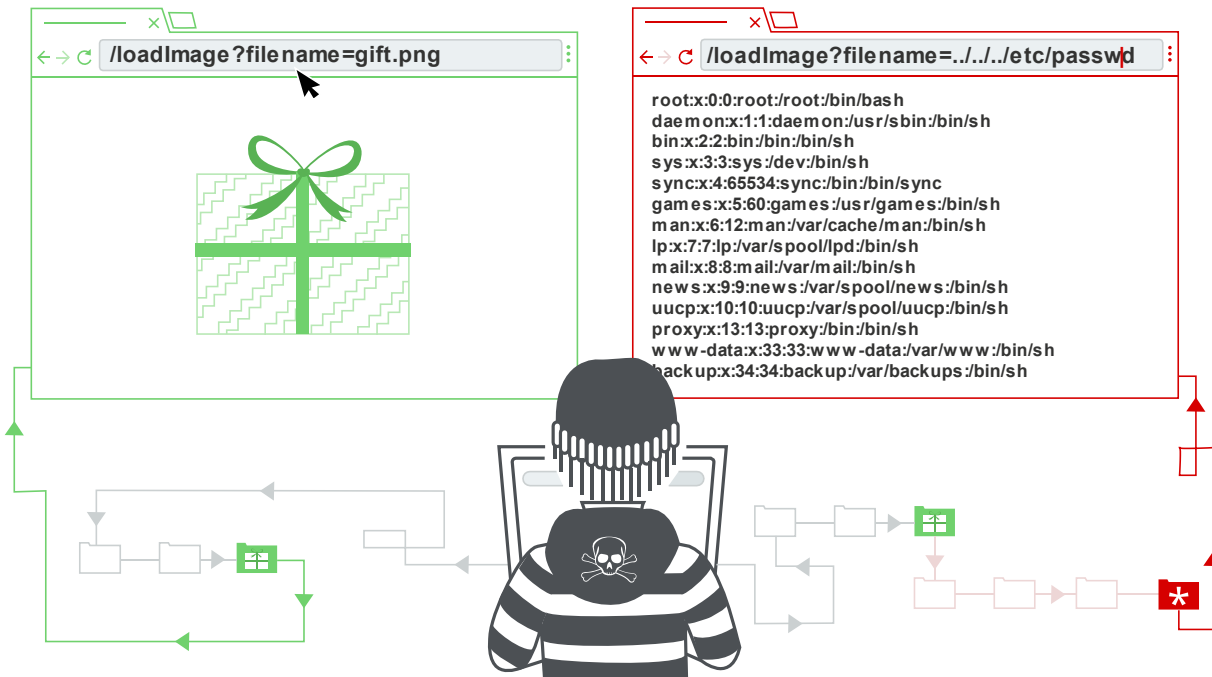
Buffer Overflow:

- A buffer is nothing but a temporary area or temporary memory for data storage.
- Buffers temporarily hold data while it is being transferred from one location to another.
- Buffer overflow occurs when volume of data exceeds storage capacity of memory buffer.
- As result program attempting to write data to buffer overwrites adjacent memory locations.
- The Attackers exploit buffer overflow issues by overwriting the memory of an application.
- The Buffer overflows occur when a program tries to write or read more data from buffer.
- A buffer overflow can give an attacker the access to different parts of the internal memory.
- Control program execution introduce risks in confidentiality, integrity and the availability.
- Forms of security vulnerabilities that frequently give potential attacker full control of PC.



Path Traversal:

- o The Path Traversal attack technique forces access to files, directories, and commands.
- o That potentially reside outside web document root directory, called Directory traversal.
- o This type of security vulnerability allows attackers to gain access to files and directories.
- o The attacker simply sends a file or directory request with the character sequence “../”.
- o Hence the alternative name “dot dot slash attack”, which points to the parent directory.



Software Bugs:

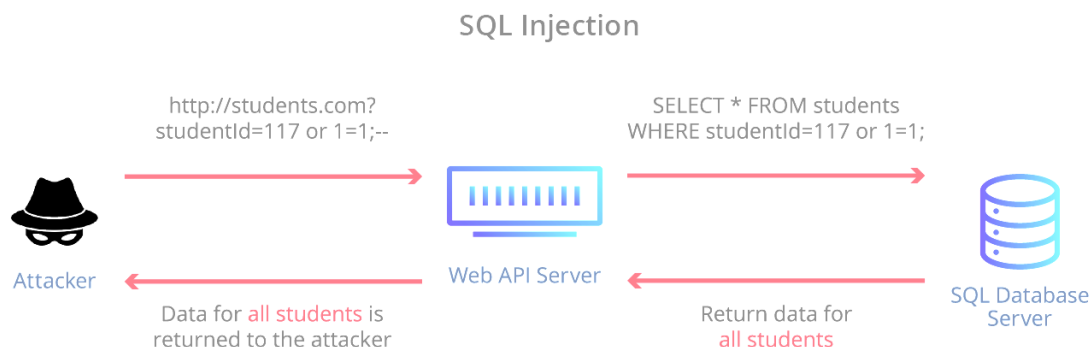
- o Software vulnerabilities involve bugs in software & bugs are coding errors.
- o Bugs are coding errors, that cause the system to make an unwanted action.
- o All software has bugs of one form or another, some bugs cause the system to crash.
- o Some cause connectivity to fail, some do not let a person to log in, & some not printing.
- o Security vulnerabilities are generally found after the software has been released to public.
- o Some vulnerabilities or software bugs might never be found in the application or software.
- o There is no way of knowing when a vulnerability and software bugs will be discovered.
- o Some bugs create info leakage or elevate user privileges or grant unauthorized access.
- o A software vulnerability is a glitch, flaw, or weakness present in the software or in an OS.

Hardcoded Passwords:

- o Hardcoded Passwords referred to as Embedded Credentials, are plain text passwords.
- o Hardcoded Passwords referred to as Embedded Credentials other secrets in source code.
- o Password hardcoding refers to the practice of embedding non-encrypted passwords.
- o Default, hardcoded passwords may be used across many of same devices, applications.
- o Embedded passwords are used in multiple ways, including Setting up new systems.
- o Hardcoded passwords may be found in Software applications, locally & cloud-based.
- o BIOS and other firmware across computers, mobile devices, servers, printers, etc.
- o Network switches, routers, firewalls, IPS, IDS, and other control and network systems.
- o Manufacturers or software companies hardcode default passwords into hardware.
- o Manufacturers hardcode default passwords into firmware, scripts and applications.
- o These products are then shipped and, often deployed, with default passwords intact.
- o Developers also embed credentials into code, for easy access as part of their workflow.
- o The Hardcoded passwords are dangerous they are easy targets for password guessing.
- o Exploits, allowing hackers & malware to hijack firmware, devices systems, and software.
- o Use of hard-coded password increases the possibility of password guessing tremendously.

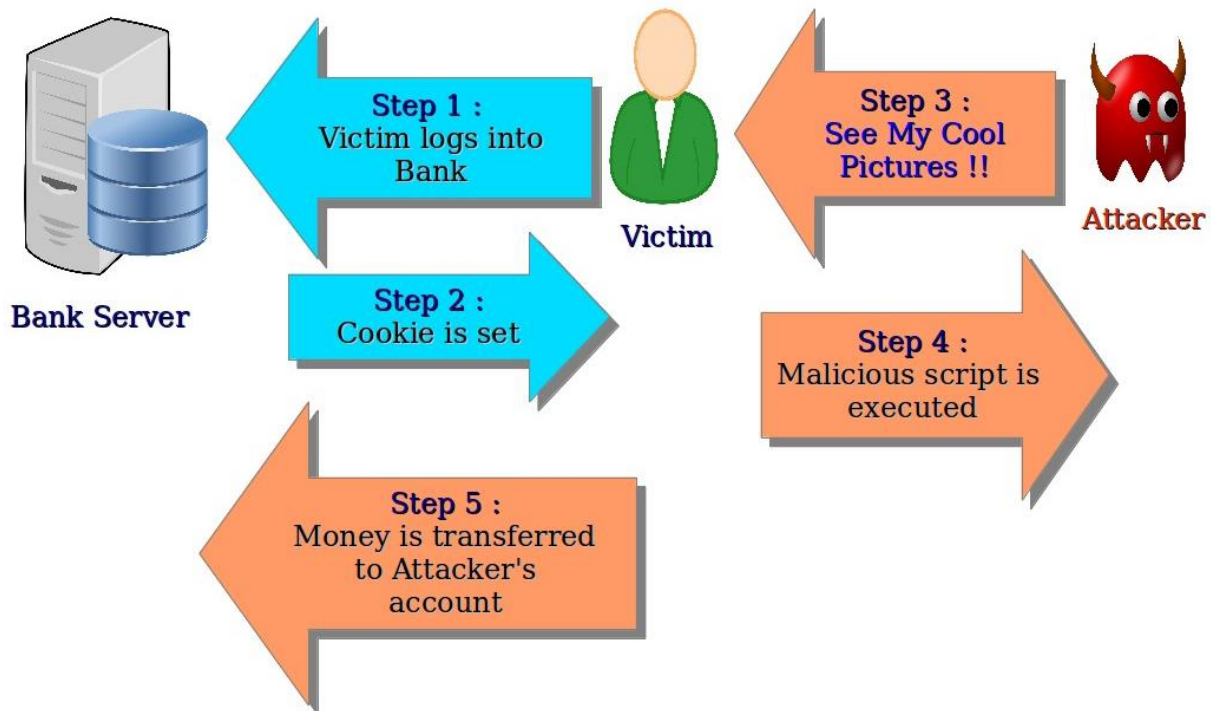
SQL Injection:

- o SQL injection is a code injection technique that might destroy your database.
- o SQL injection is one of the most common web hacking techniques to gain access.
- o SQL injection is placement of malicious code in SQL statements, via web page input.
- o SQL Injection is injection attack makes possible to execute malicious SQL statements.
- o Attackers can use SQL Injection vulnerabilities to bypass application security measures.
- o SQL Injection (SQLi) also used to add, modify, and delete records in the database.
- o SQL injection attack exploits vulnerable cloud-based applications allow pass SQL commands.
- o Injection is a security vulnerability that allows an attacker to alter backend SQL statements.



Cross-Site Scripting Forgery:

- o Cross-site request forgery (also known as CSRF) is a web security vulnerability.
- o Cross-site request forgery, also known as one-click attack or session riding or XSRF.
- o Attack that forces an end user to execute unwanted actions on a web application.
- o A successful CSRF attack can be devastating for both the business and the user.
- o Web security vulnerability that allows an attacker to induce users to perform actions.
- o Successful CSRF attack, attacker causes victim user to carry out action unintentionally.
- o This might be to change the email address on their account, to change their password.
- o Cookies are vulnerable to CSRF because they are automatically sent with each request.
- o Allows attackers to easily craft malicious requests that lead to Cross-site request forgery.



Missing Encryption:

- o Software does not encrypt sensitive or critical info before storage or transmission.
- o The weakness exists due to lack of correct sensitive or important data encryption.
- o As application doesn't use secure channel attackers can easily obtain sensitive data.
- o Missing encryption vulnerability allows malicious users to modify application data.
- o This weakness is introduced during Architecture and Design, Implication stages.